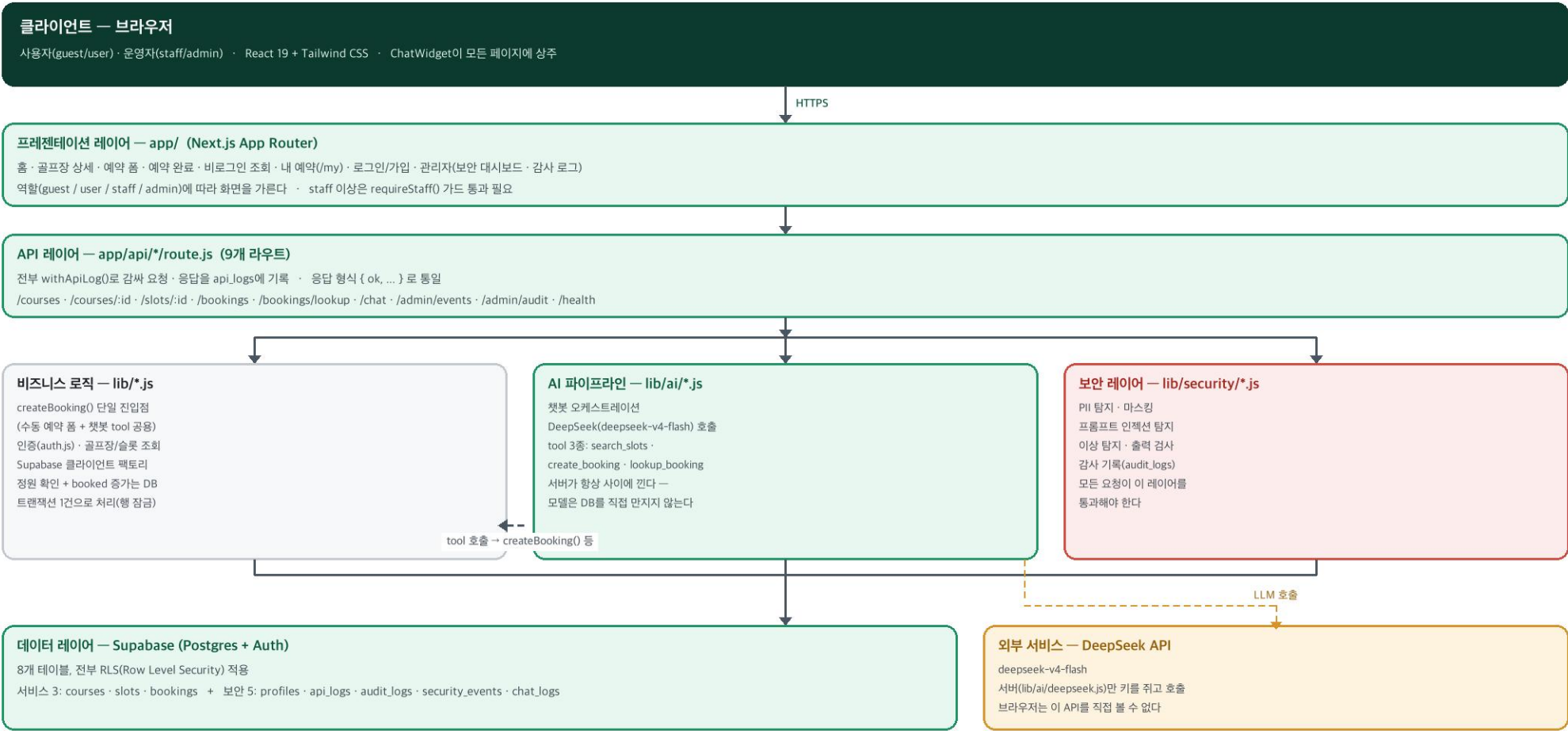




핵심 설계 원칙 (CLAUDE.md 절대 규칙)

- createBooking() 단일 진입점 — 수동 폼과 챗봇이 항상 같은 함수를 쓴다
- 챗봇은 DB를 직접 건드리지 않는다 — 서버가 제공하는 tool만 호출한다
- 키는 서버에만 존재 — NEXT_PUBLIC_ 접두사로 클라이언트에 노출 금지
- 로그에 원본 PII 금지 — 원본 PII는 bookings 테이블 하나뿐, 나머지는 마스킹
- 보안 로직은 lib/security/에만 — 라우트마다 정규식을 흩뿌리지 않는다
- DB는 snake_case, JS는 camelCase — 변환은 lib/ 안에서 한 번만 한다

요청 흐름 예시 — 챗봇 예약 시나리오

- ChatWidget → POST /api/chat (withApiLog가 진입 시각 기록)
- chatService.js — 입력 검사 → 인젝션 탐지 → PII 탐지 (순서 고정)
- DeepSeek 호출 → search_slots tool → 슬롯 조회 결과를 모델에 반환
- 이름 · 전화 제공 → create_booking tool → lib/bookings.js 호출
- bookings에 원본 저장, audit_logs·chat_logs 기록(전화번호는 마스킹)
- outputGuard.js가 출력 검사 후 응답 반환, api_logs에 duration 기록